Actividad 3 · Seguridad de acceso remoto

TELNET frente a SSH · Endurecimiento OpenSSH · SFTP/SCP · Túneles · fail2ban

Guía integral de ejecución, evidencias, informe técnico APA 7, bitácora de IA y defensa oral

Tecnología Web I · Ingeniería de Sistemas · Semestre 2/2026

Escenario: Windows PowerShell 7 como equipo anfitrión y servidor Ubuntu 24.04 en VM o contenedor Docker con systemd, según los laboratorios disponibles.

Documento didáctico. Sustituir nombres, IP, puertos y rutas de ejemplo por los del entorno real. No se incluyen capturas inventadas: cada estudiante debe generar las suyas.

1. Propósito y criterios de logro

Demostrar experimentalmente que TELNET transmite credenciales y comandos sin protección criptográfica, mientras SSH protege el contenido de la sesión; después, dejar el servidor accesible exclusivamente mediante SSH con autenticación por clave y controles complementarios.

Entregable	Evidencia verificable
Comparación TELNET/SSH	Dos archivos .pcapng/.pcap, filtros, Follow TCP Stream y tabla analítica
SSH endurecido	Claves ed25519, configuración efectiva, rechazo de root/contraseña y puerto autorizado
Operación segura	Transferencias SCP/SFTP y túnel local funcional
Defensa ante intentos	fail2ban activo, IP de prueba bloqueada y registro de eventos
Comunicación académica	Informe APA 7, bitácora IA, repositorio GitHub y presentación
Defensa	Demostración en vivo y explicación de decisiones y límites

2. Antes de comenzar: seguridad y preparación

Solo ejecutar pruebas sobre una red privada de laboratorio y equipos propios/autorizados. TELNET se habilita temporalmente y se elimina al terminar. Usar cuentas y contraseñas ficticias, jamás credenciales reales. No publicar claves privadas, contraseñas, direcciones sensibles ni capturas sin anonimizar. Conservar acceso por consola de VM o docker exec para recuperar el servidor si SSH queda inaccesible.

En Docker, los cambios de firewall y fail2ban pueden requerir capacidades NET_ADMIN, journald y networking apropiado; un contenedor mínimo sin systemd no reproduce estos pasos. Preferir una VM Ubuntu para la prueba integral si el paquete de laboratorio no proporciona esas capacidades.

3. Inventario del entorno

Dato	Ejemplo / completar
IP servidor	192.168.56.10 (sustituir)
Usuario administrador	ana (sustituir)
Puerto SSH inicial	22

Puerto SSH final	2222 (ejemplo; elegir según consigna y Docker)
Puerto TELNET temporal	23
API interna	127.0.0.1:8081
Puerto local del túnel	9081
Ruta sitio	/srv/horizonte/www

4. Laboratorio 10 — capturar TELNET y SSH

4.1 Comprobar conectividad y herramientas

PowerShell de Windows (cliente):

```
ssh -V
Test-NetConnection 192.168.56.10 -Port 22
Get-Command ssh, scp, sftp
```

Terminal Ubuntu (servidor):

```
sudo apt update
sudo apt install -y openssh-server tcpdump tshark telnetd openbsd-inetd inetutils-telnet
sudo systemctl enable --now ssh
sudo ss -lntp | grep -E ":(22|23) "
```

Si TELNET no escucha, habilitarlo únicamente en la red aislada:

```
sudo update-inetd --enable telnet
sudo systemctl restart openbsd-inetd
sudo ss -lntp | grep ":23 "
```

4.2 Crear cuenta ficticia y capturar TELNET

Crear usuario de prueba con contraseña temporal que NO se use en ningún otro sistema. La demostración debe hacerse desde otro equipo o contenedor de la misma red, de modo que se capture en la interfaz correcta.

```
sudo adduser pruebaweb
ip -br addr
sudo tcpdump -i any -nn -s 0 -w /tmp/telnet_lab10.pcap "tcp port 23"
```

En otra terminal del cliente Linux ejecutar telnet 192.168.56.10, ingresar la cuenta ficticia, ejecutar «echo MENSAJE_LAB10», salir con exit y detener tcpdump con Ctrl+C. Si Windows no tiene cliente TELNET, usar un segundo contenedor/VM con inetutils-telnet; no habilitar TELNET fuera de la red privada.

4.3 Capturar SSH con el mismo contenido

```
sudo tcpdump -i any -nn -s 0 -w /tmp/ssh_lab10.pcap "tcp port 22"
```

En otra terminal del cliente ejecutar ssh pruebaweb@192.168.56.10, autenticarse temporalmente por contraseña ANTES del endurecimiento, ejecutar «echo MENSAJE_LAB10» y salir. Detener tcpdump. Para una comparación justa, realizar las dos pruebas antes de deshabilitar la autenticación por contraseña.

4.4 Abrir las capturas en Wireshark (Windows)

Transferir los PCAP al anfitrión mediante una carpeta compartida o docker cp; no subirlos a GitHub si contienen contraseñas. Abrir cada archivo en Wireshark y aplicar filtros «tcp.port == 23» y «tcp.port == 22». Elegir un paquete de la conversación → botón derecho → Follow → TCP Stream. En TELNET el flujo permite reconstruir usuario, contraseña y contenido (la contraseña puede aparecer carácter por carácter). En SSH se observa el saludo de versión y metadatos del protocolo, pero no el texto del comando ni la contraseña.

Pregunta	TELNET	SSH
¿Se identifica el usuario en el flujo?	Sí, normalmente	No como texto legible en la carga cifrada
¿Se reconstruye la contraseña?	Sí, en una sesión clásica	No
¿Se lee MENSAJE_LAB10?	Sí	No
¿Qué queda visible?	Datos de aplicación	IP, puertos, tamaños, tiempos y banner de versión

Evidencias E01-E04: captura con filtro TELNET; Follow TCP Stream TELNET con datos ficticios; captura SSH; Follow TCP Stream SSH. Acompañar cada imagen de fecha, equipo, interfaz, filtro y conclusión. El número de paquetes variará.

4.5 Retirar TELNET inmediatamente

```
sudo update-inetd --disable telnet
sudo systemctl disable --now openbsd-inetd
sudo apt purge -y telnetd
sudo ss -lntp | grep ":23 " || echo "Puerto 23 cerrado"
```

5. Laboratorio 11 — SSH endurecido

5.1 Crear claves ed25519 en el CLIENTE Windows

```
ssh-keygen -t ed25519 -a 64 -f "$HOME\.ssh\id_ed25519_horizonte" -C "actividad2-admin"
Get-Content "$HOME\.ssh\id_ed25519_horizonte.pub"
```

Proteger la clave privada con frase de paso. Copiar exclusivamente la línea .pub a /home/ana/.ssh/authorized_keys en el servidor. En PowerShell, puede mostrarse la clave pública y pegarse en la consola del servidor. No pegar nunca el archivo sin extensión .pub.

```
sudo install -d -m 700 -o ana -g ana /home/ana/.ssh
sudo nano /home/ana/.ssh/authorized_keys
sudo chown ana:ana /home/ana/.ssh/authorized_keys
sudo chmod 600 /home/ana/.ssh/authorized_keys
```

Desde Windows verificar acceso por clave ANTES de apagar contraseñas:

```
ssh -i "$HOME\.ssh\id_ed25519_horizonte" ana@192.168.56.10
```

5.2 Crear grupo permitido y respaldar configuración

```
sudo groupadd -f sshadmins
sudo usermod -aG sshadmins ana
sudo cp /etc/ssh/sshd_config /etc/ssh/sshd_config.bak-actividad2
sudo mkdir -p /etc/ssh/sshd_config.d
```

5.3 Archivo de endurecimiento

Crear /etc/ssh/sshd_config.d/01-actividad2.conf con las líneas siguientes. Ubuntu puede incluir archivos previos que sobrescriban por precedencia: comprobar siempre la configuración efectiva con sshd -T. Cambiar el puerto exige adaptar Docker Compose/puertos publicados y reglas de firewall, y puede requerir reinicio del contenedor.

```
Port 2222
PermitRootLogin no
PasswordAuthentication no
KbdInteractiveAuthentication no
PubkeyAuthentication yes
AuthenticationMethods publickey
AllowGroups sshadmins
```

```
MaxAuthTries 3
LoginGraceTime 20
X11Forwarding no
AllowAgentForwarding no
LogLevel VERBOSE
AllowTcpForwarding local
```

Mantener AllowTcpForwarding local para que el túnel requerido funcione; ponerlo en «no» impediría la demostración. El puerto alternativo reduce ruido automatizado, pero no reemplaza las claves y restricciones.

5.4 Validar sin perder acceso

```
sudo /usr/sbin/sshd -t
sudo /usr/sbin/sshd -T | grep -E
"^(port|permitrootlogin|passwordauthentication|kbdinteractiveauthentication|authenticationmethods|
allowgroups|allowtcpforwarding) "
sudo systemctl restart ssh
sudo ss -lntp | grep 2222
```

Dejar una sesión SSH previa abierta y probar una SEGUNDA sesión desde Windows. Si el puerto no abre, revisar UFW, NAT, docker compose y journalctl; no cerrar la sesión de recuperación.

```
ssh -p 2222 -i "$HOME\.ssh\id_ed25519_horizonte" ana@192.168.56.10
ssh -p 2222 -o PubkeyAuthentication=no -o PreferredAuthentications=password ana@192.168.56.10
ssh -p 2222 root@192.168.56.10
```

La primera debe funcionar; las otras deben rechazarse. Los intentos de root deben hacerse de forma limitada, exclusivamente como prueba autorizada. Guardar E05-E08: configuración efectiva, acceso válido, contraseña rechazada y root rechazado.

5.5 Identidad del servidor y huella

```
sudo ssh-keygen -lf /etc/ssh/ssh_host_ed25519_key.pub
```

Comparar la huella por un canal confiable antes de aceptar la primera conexión. Si aparece REMOTE HOST IDENTIFICATION HAS CHANGED, NO ejecutar ssh-keygen -R sin verificar primero que el cambio sea legítimo. En clones, generar claves de host únicas durante aprovisionamiento controlado.

6. SCP, SFTP y túnel local

En PowerShell, crear un archivo de prueba y transferirlo a una carpeta donde ana tenga permisos. La ruta web puede necesitar grupo webadmin configurado en laboratorios anteriores.

```
"Prueba segura Actividad 2" | Set-Content "$HOME\Desktop\prueba_ssh.txt"
scp -P 2222 -i "$HOME\.ssh\id_ed25519_horizonte" "$HOME\Desktop\prueba_ssh.txt"
ana@192.168.56.10:/home/ana/
sftp -P 2222 -i "$HOME\.ssh\id_ed25519_horizonte" ana@192.168.56.10
```

Dentro de sftp ejecutar ls, put y get con un archivo ficticio; documentar los resultados. Para un usuario SFTP sin terminal se puede añadir una cuenta y una regla Match específica, pero no es requisito mínimo de la consigna. Si se aplica ChrootDirectory, todos los directorios superiores deben pertenecer a root y no ser escribibles por otros.

Túnel hacia una API que escucha únicamente en el servidor, en 127.0.0.1:8081:

```
ssh -p 2222 -i "$HOME\.ssh\id_ed25519_horizonte" -N -L 9081:127.0.0.1:8081 ana@192.168.56.10
```

En otra ventana de PowerShell:

```
Invoke-WebRequest http://127.0.0.1:9081/eco | Select-Object -ExpandProperty Content
```

El endpoint /eco es un ejemplo del laboratorio previo; sustituirlo por un endpoint real. Si no existe un servicio interno, iniciarlo previamente y verificarlo en el servidor. Cerrar el túnel con Ctrl+C y confirmar que el puerto local deja de responder. Evidencias E09-E11: SCP, SFTP y túnel con respuesta.

7. fail2ban y prueba controlada de bloqueo

Instalar en Ubuntu con systemd y nftables habilitados:

```
sudo apt install -y fail2ban python3-systemd nftables
sudo mkdir -p /etc/fail2ban/jail.d
sudo nano /etc/fail2ban/jail.d/actividad2.local
```

Contenido del archivo (sin comentarios al final de líneas de valores):

```
[DEFAULT]
backend = systemd
banaction = nftables-multiport
ignoreip = 127.0.0.1/8 ::1

[sshd]
enabled = true
port = 2222
mode = aggressive
maxretry = 4
findtime = 10m
bantime = 10m
journalmatch = _SYSTEMD_UNIT=ssh.service + _COMM=sshd
sudo systemctl enable --now fail2ban
sudo systemctl restart fail2ban
sudo fail2ban-client status sshd
sudo journalctl -u fail2ban -n 30 --no-pager
```

Prueba: desde una SEGUNDA VM/contenedor de la red aislada, con IP diferente de la del administrador, realizar manualmente 4–6 conexiones SSH fallidas con nombres de usuario ficticios. Evitar automatizar grandes volúmenes y no probar contra redes externas. Verificar que el origen no esté en ignoreip y que el tráfico alcance directamente el servicio: con NAT Docker todos los intentos pueden verse como una misma IP de gateway.

```
ssh -p 2222 -o BatchMode=yes usuario_inexistente@192.168.56.10
# Repetir manualmente unas pocas veces desde la IP de prueba
sudo fail2ban-client status sshd
sudo journalctl -u fail2ban --no-pager | tail -30
sudo nft list ruleset | grep -A 12 f2b
```

Registrar la IP bloqueada y el evento Ban, sin exponer IP pública real. Si no aparece bloqueo, revisar journalmatch, backend, puerto, conectividad y logs SSH. Para restaurar acceso de la IP de prueba: sudo fail2ban-client set sshd unbanip IP_DE_PRUEBA. Evidencias E12-E14: estado de jaula, eventos Found/Ban y bloqueo efectivo.

8. Matriz de evidencias obligatorias

Código	Captura / archivo	Qué demuestra
E01	TELNET Wireshark	Puerto 23 y paquetes
E02	TELNET Follow Stream	Credenciales ficticias legibles
E03	SSH Wireshark	Puerto SSH y tráfico
E04	SSH Follow Stream	Carga no legible
E05	sshd -T	Controles efectivos

E06	Clave ed25519	Huella pública; jamás privada
E07	Acceso por clave	Conexión permitida
E08	Rechazos	Root y contraseña denegados
E09	SCP	Archivo transferido
E10	SFTP	put/get completados
E11	Túnel local	API interna accesible vía 9081
E12	fail2ban status	Jaula activa
E13	Logs fail2ban	IP detectada y baneada
E14	Prueba de bloqueo	Conexión desde origen bloqueado
E15	TELNET retirado	Puerto 23 cerrado

9. Informe técnico conforme a APA 7

Formato sugerido de trabajo estudiantil APA 7: márgenes 2,54 cm, interlineado doble, número de página arriba a la derecha, fuente legible (p. ej. Times New Roman 12 o Arial 11), títulos jerárquicos y citas autor-fecha. La portada debe indicar título, autor(es), afiliación, asignatura, docente y fecha. No inventar fuentes ni resultados.

Estructura recomendada: portada; resumen (si el docente lo requiere); introducción y objetivo; marco conceptual con referencias; entorno y metodología; resultados TELNET vs SSH; endurecimiento; transferencias y túnel; fail2ban; discusión de limitaciones; conclusiones; referencias; anexos de evidencias y bitácora IA.

Cada figura: «Figura N», título en cursiva, imagen y nota con descripción, autoría y fecha. En el cuerpo: «Como se observa en la Figura 3...». Para resultados propios, indicar elaboración propia; para material ajeno, citarlo. Adjuntar rutas relativas a los archivos de evidencia.

10. Bitácora de IA: plantilla obligatoria

Fecha / paso	Consulta a IA	Respuesta resumida	Decisión crítica / corrección	Verificación y evidencia
[fecha]	[prompt exacto]	[resumen]	[acepté/rechacé y por qué]	[comando, captura, resultado]
[fecha]	[prompt exacto]	[resumen]	[acepté/rechacé y por qué]	[comando, captura, resultado]

Reflexión final: describir al menos un error o supuesto de la IA que fue comprobado y corregido. Ejemplo: confundir sshd.service con ssh.service en Ubuntu 24.04. No compartir secretos ni claves privadas en prompts.

11. Repositorio GitHub y presentación

Estructura sugerida: README.md, informe/Informe_Actividad2.pdf, bitacora/BITACORA_IA.md, evidencias/ (capturas anonimizadas), configuracion/ (solo ejemplos sin secretos), presentacion/Actividad2.pptx o .html o .pdf. Los PCAP con credenciales se conservan fuera del repositorio o se sanitizan cuidadosamente. Añadir .gitignore para *.key, id_ed25519*, *.pcap, *.pcapng, .env y credenciales.

En el README incluir objetivo, topología, instrucciones de reproducción, resultados, advertencias y URL de la presentación. Insertar enlace público o accesible al repositorio en la portada/anexo del informe y comprobarlo en navegador sin iniciar sesión.

Presentación de 8–10 diapositivas: problema; topología; TELNET; SSH; tabla comparativa; claves y controles; SCP/SFTP/túnel; fail2ban; resultados y límites; conclusiones + repositorio. Usar capturas propias legibles y explicar su significado, no solo mostrarlas.

12. Defensa del informe: guion y preguntas

Tiempo sugerido: 8 minutos de exposición + 5 minutos de preguntas. Demostración mínima: mostrar los dos Follow TCP Stream, ejecutar sshd -T, conexión válida por clave, rechazo de contraseña, estado fail2ban y cierre de TELNET. Preparar una recuperación por consola si hay fallo.

• ¿Qué datos permanecen visibles en SSH aunque el contenido esté cifrado?

• ¿Por qué cambiar el puerto no sustituye la autenticación por claves?

• ¿Qué diferencia existe entre clave de host y clave del usuario?

• ¿Por qué no se debe borrar known_hosts sin verificar una huella cambiada?

• ¿Cómo demostraría que PasswordAuthentication no está efectivo?

• ¿Qué sucede si AllowTcpForwarding está en no?

• ¿Por qué fail2ban podría no detectar eventos en Ubuntu 24.04?

• ¿Qué limitaciones tiene una prueba de bloqueo detrás de Docker NAT?

14. Diagnóstico de errores frecuentes

Problema	Comprobación / solución
Permission denied (publickey)	Revisar authorized_keys, dueño y permisos 700/600; ssh -vvv
No abre puerto 2222	ss -lntp, firewall, puertos Docker, sshd -t, journalctl -u ssh
Se perdió acceso SSH	Entrar por consola VM/docker exec y restaurar respaldo
Huella de host cambió	Verificar huella por canal independiente antes de actualizar known_hosts
Wireshark no muestra paquetes	Capturar en interfaz correcta; tráfico loopback usa lo
SFTP Permission denied	Permisos del directorio destino; chroot requiere root:root
Túnel no responde	Comprobar API en 127.0.0.1:8081 y AllowTcpForwarding local
fail2ban sin Ban	Verificar journalmatch, IP real de origen y nftables
Puerto 23 sigue abierto	Revisar inetd y telnetd; repetir ss -lntp

15. Lista final de aceptación

☐ Se documentó tráfico TELNET legible y SSH cifrado.

☐ Se retiró TELNET y se comprobó puerto 23 cerrado.

☐ El acceso SSH válido utiliza ed25519 y frase de paso.

☐ Root y autenticación por contraseña están deshabilitados.

☐ Puerto, usuarios/grupos permitidos y configuración efectiva están documentados.

☐ SCP, SFTP y túnel local tienen evidencias.

☐ fail2ban detectó y bloqueó un origen controlado.

☐ Informe y bitácora siguen APA 7 y no contienen secretos.

☐ GitHub y presentación son accesibles.

☐ El equipo puede defender decisiones, resultados y limitaciones.

Referencias orientativas (verificar edición y URL consultadas)

American Psychological Association. (2020). Publication manual of the American Psychological Association (7th ed.).

OpenSSH. (s. f.). OpenSSH manual pages. https://www.openssh.com/manual.html

Wireshark Foundation. (s. f.). Wireshark user's guide. https://www.wireshark.org/docs/wsug_html_chunked/

Fail2ban. (s. f.). Fail2ban documentation. https://fail2ban.readthedocs.io/

Ubuntu. (s. f.). OpenSSH server documentation. https://documentation.ubuntu.com/server/how-to/security/openssh-server/

Nota: ejemplos alineados con los solucionarios docentes de laboratorios 10 y 11 proporcionados; las salidas y los números de paquetes del documento de referencia no deben presentarse como resultados propios.